Lab 5: Static Code Analysis

Project: Scholarship Disbursement Ledger
Student: Spoorthy M | **SRN:** PES1UG24AM280

1. Objective

Review the assigned Python program with Pylint, Bandit, and Flake8; address security, quality, and formatting defects; and show the improvements using three separate code-fix commits.

2. Original issues and corrections

Issue	Why it matters	Correction
Unsafe SQL formatting	Values may change the SQL query	Bound parameters (?)
os.system() call	Shell execution is unnecessary	Commit and print without shell
Mutable default list	Audit state leaks between calls	Default None, create fresh list
Global state	Disbursement counter hard to maintain	Use returned amounts in main
Repeat disbursement	Award may be paid twice	Check disbursed flag
Wrong None comparison	PEP 8 style issue	Use is None
Naming and line length	Inconsistent style	snake_case and wrapped lines

3. Git change history

The archive contains a local Git repository with a baseline snapshot and three commits dedicated to (1) Bandit/security, (2) Pylint/code quality, and (3) Flake8/style. Run `git log --oneline -4` in the extracted folder to inspect them.

4. Verification procedure

Install the three static analysis tools, then run `generate_reports.ps1` on Windows or `generate_reports.sh` on Linux/macOS. These scripts produce genuine before/after analysis outputs under `before/` and `after/`. Check that Pylint exceeds 9.5, Bandit has no unresolved findings and Flake8 reports no style violations. These external tool outputs have not been fabricated or claimed as executed in this environment.

5. Functional validation

The updated program has checks for granting awards, counting schemes, non-existent IDs, independent audit lists, and preventing a second disbursement. Run `python -m unittest tests_scholarship.py` in the project folder.

6. Reflection

Pylint improves code quality, Bandit highlights unsafe coding patterns, and Flake8 detects style problems. Parameterized SQL was a critical security correction. The exercise shows that working code can still have hidden vulnerabilities and maintenance problems, and that static checks complement rather than replace functional tests.

7. Submission checklist

Updated source file; three Git fix commits; Pylint, Bandit, and Flake8 before/after reports; issues table; reflection; final report. The six report text files must be generated locally after installing the tools.